

Analysis

Main Problem

Many web systems are connected to the internet and can be reached by anyone, which makes them a target for attacks. If a system is poorly built, small mistakes in the code can let someone steal data, log in without permission, or damage the system. Many of these problems happen because developers do not fully understand how their own system can be attacked. This project helps me understand this problem from both sides: by building a system, breaking into it myself, and then fixing it, I can learn how these weaknesses happen and how to prevent them, instead of only reading about them.

Project description

The Main idea is to design small virtual network with multiple machines that can communicate with each other. Build a simple web application with a login and backend that checks data in data base and inform is provided data is correct. Take on the role of a hacker and take over transferred data. Fix the problem and verify if the same attack will fail next time.

Requirements

System Must Have:

- A web app with a login form
- A backend that takes the login data, sends it to the database, checks if it's correct, and sends the result back.
- A database that stores user data.
- The backend's login is **intentionally vulnerable** (weak on purpose).
- Virtual machines and a network environment where hacking can be done safely.
- Proof of a successful attack on the vulnerable web application.
- A fixed version of the backend, tested against the same attack.
- Web/database servers run on a separate machine from the attacker.
- Security starts weak, so it can be broken into.

- All work is documented so it can be repeated and understood.

System Could Have:

- Proof of more than one type of successful attacks on the web application and solution to these problems.

Research

What I already know:

- How to build a simple website with a login page using HTML and CSS.

What I need to learn:

- | | | |
|----|--|--|
| 1. | How to use EduCloud/Netlab | To create and manage all my VMs and network |
| 2. | Networking basics (IP, ports, DHCP, Client/Server, TCP, HTTP, HTTPS, Request/Response) | To understand how devices find each other, and how they send and receive data. |
| 3. | How a database works | To store and retrieve usernames and passwords |
| 4. | What SQL is and how it works | To manage data in a database |

- | | | |
|----|--|--|
| 5. | How a backend works and communicates with a database | To learn how my backend checks login data against the database and sends back the result, and to know where the weakness is so I can attack it and later fix it. |
| 6. | How hacking works, types of attacks | To learn which ways I can attack my backend, and what attack options exist. |
| 7. | A thinking method for security weaknesses | To learn a structured way to search for weaknesses, instead of guessing randomly. |
| 8. | How to improve security | To learn how to close the weakness I found, so the same attack no longer works |

Advise

For this project, I had to make a few key decisions: which backend language i will use, how many virtual machines i should set up, and whether the database should run on its own machine. Below I'm comparing the options for each.

Programing languages

Options:

PHP

Python

JavaScript

My choice: Python

Why:

- I already know basics of Python from workshop and want to use this knowledge.
- Flask and backend development are new areas for me.
- Python is widely used in cybersecurity.
- It is useful for future security related projects.

Number of VMs

Options:

- 2 VMs: attacker, web and database server in one (this is easier way to build this project but less realistic)
- 3 VMs: attacker, web server, database server (The most realistic scenario)

My choice: 3 VMs

Why:

- Separate database server
- Gives me more realistic network communication between machines.
- Helps me practice Network & Cloud concepts.
- Allows me to study communication between the web server and database.

SQL System

Options:

- MySQL

(Very popular, relatively easy to learn system, mainly used for web applications)

- PostgreSQL

(More advanced and offers more complex SQL features. Good for applications and more advanced data systems)

- MariaDB

(A MySQL-compatible alternative that was developed as a fork of MySQL. It is commonly used in Linux and web environments)

- Microsoft SQL Server

(Created by Microsoft, commonly used in business environments, especially with other Microsoft technologies)

My choice: MySQL

Why: Because the project does not require highly advanced database features, so

using a simpler and widely used solution for web applications will allow me to focus on completing the entire project on time while keeping the system clear and easy to manage.

Plan

Week 1 - 2

In the first two weeks, I want to learn the topics I need to understand how this project works. This includes using EduCloud, basic networking, how a database works, SQL, how a backend communicates with a database, types of attacks, and a structured way to find security weaknesses. This fits well with the Networking & Cloud Basics workshop planned for week 1.

At the same time, I want to start building the virtual network and the VM environment. This gives me hands-on practice with the same networking ideas I am learning.

Week 3 - 4

In week 3 I will build the web application. This includes a login form, a backend, and a connection to the database. First, I will make sure this works correctly as a normal login system.

Next, I will make the backend deliberately weak, based on the attack types I researched earlier. I will attack my own weakened system and record the results as proof that the attack worked. After that, I will fix the weakness and repeat the same attack to check that it no longer succeeds.